CASE REPORT | TIER 1 HEALTHCARE IT SUPPORT | RESTRICTED INCIDENT RECORD

Case Report — TKT-00517

Suspected phishing and credential misuse with possible ePHI involvement | Six required sections in the locked template order

SYNTHETIC DATA Training case built only from the TKT-00517 evidence packet. All identifiers are minimized under the PHI Redaction Procedure (Component 4). Nothing in this report determines breach, impermissible use or disclosure, notification, severity, or actual access; those determinations are reserved to the designated functions.

Case metadata

Field	Learner entry
Ticket number	TKT-00517 (P2 — suspected identity compromise with possible ePHI involvement); linked restricted ServiceNow security incident SIR-00517†
Learner	
Report timestamp and time zone	09/03/2026 09:40 ET† (Eastern Time; all times in this report are ET)
SOP/runbook versions used	First-Line Cybersecurity Response Procedure — Training SOP FLR-01, Version 1.0 Four Cybersecurity Threat Categories — no version number shown Basic Cloud Security Check Procedure — Version 1.0 Data Security Safeguards Reference — no version number shown PHI Redaction Procedure and Verification Checklist — Version 1.0 HIPAA Compliance Checklist — no version number shown HIPAA SOPs and Pre-Approved Runbooks — Version 1.0, effective 09/04/2026 (IR-01, EVID-01, PRIV-01, PRIV-02, M365-01); effective-date question flagged in Component 5 Escalation Team Reference — Version 1.0 Case Report Template and Warm-Transfer Summary Template — no version number shown
Evidence exhibits	A-01 — Shared clinical file: storage, sharing, and Purview access record (packet Evidence D); the file itself is referred to as “Artifact A-01” A-02 — Ticket intake and reporter statement (ticket-note excerpt) A-03 — Suspicious message excerpt (packet Evidence A) A-04 — Microsoft Entra sign-in extract (packet Evidence B; diagnostic log lines) A-05 — Account security posture extract (packet Evidence C) All exhibits are redacted working copies; originals are preserved unchanged in the restricted evidence repository under SIR-00517†.
Simulation key	† marks a simulated value: Tier 1 action times, ServiceNow record IDs, and acknowledgments on the 09/03/2026 training timeline, which begins after the ticket opened at 08:44 ET. Times without † come directly from the TKT-00517 evidence packet.

1. Component 1 - Cybersecurity Containment

The full ticket and evidence packet (A–D) were read at 08:46 ET† before any action was taken. Three concerns were identified: a phishing pattern (impersonated “Epic Support” message), an account security concern (credentials entered, then an unfamiliar successful sign-in), and a shared-file concern (a PHI-bearing SharePoint file with an Anyone link and a file-access event in the same window).

Required field	Learner entry
Threat category	**Category 2 — Credential compromise / account takeover (suspected).** Multi-stage chain (Four Cybersecurity Threat Categories): entered through **Category 1 — Phishing / social engineering**; the 08:32 ET file-access event raises an open **Category 4 — Unauthorized access / data exposure** question that Tier 1 does not determine. Category 3 — Malware / ransomware: no signals in the packet (no security alert, attachment, process, or encryption event).
Signal 1	**Phishing message and credential entry.** Received 09/03/2026 08:14 ET; display name “Epic Support”; external sender epic-support@access-review[.]example; subject “Urgent: verify clinical access”; link shown hxxps://verify-access[.]example/contoso; Message ID <synthetic-00517@access-review.example> (A-03). Reporter states the message threatened access suspension and that at about 08:17 ET the link was selected and the work username and password were entered; the page then stopped responding (A-02). Signals matched: impersonated sender, urgent request, deceptive link, credential prompt; credentials entered on an untrusted page. (Indicators defanged for safe handling.)
Signal 2	**Unfamiliar successful sign-in after credential entry.** Entra: 08:29 ET Success from 198.51.100.24 / Phoenix, AZ, risk signal “Unfamiliar sign-in properties,” device ID unavailable; 08:36 ET Failure 50053 from the same IP, “High-confidence risk block” (A-04). Reporter states they are working in Boston today and have not traveled this week; the earlier 08:11 ET sign-in was Success from 192.0.2.18 / Boston, MA on CH-CLIN-044 with no risk signal (A-02, A-04). Recorded as a signal, not proof of compromise.
Signal 3 (supporting)	**File-access event in the same window.** Purview FileAccessed on Artifact A-01 at 09/03/2026 08:32 ET by the Affected Workforce Account from 198.51.100.24 (A-01). The event does not establish who controlled the session.
Authorized containment action	Actor: Tier 1 Healthcare IT Support (TKT-00517 assignee). Step 1 of 3 — Isolate / contain (FLR-01 Action 1; entry criteria 1–3 met): • 08:48 ET† — Opened restricted ServiceNow security incident SIR-00517†. Result: opened. • 08:49 ET† — Instructed the Attending Physician by phone to stop interacting with the message (do not reopen the link, reply, forward, or delete it; do not add patient details to the ticket) and gave the approved downtime / alternate-access route in case containment interrupts access; no shared emergency account offered (FLR-01 care-continuity checks). Result: reporter confirmed†. • 08:55 ET† — Immediately engaged the SOC (WT-00517-SOC†), then IAM at 09:03 ET† (WT-00517-IAM†), requesting session revocation and password reset under the authorized role (FLR-01 Action 1, “immediately engage SOC/IAM”; IR-01.B). Result: both acknowledged†; IAM execution result pending IAM confirmation. No Tier 1 pre-approved identity containment workflow is defined in the supplied procedures. Tier 1 therefore did **not** disable the account, revoke sessions, reset the password, or confirm or dismiss risk; those actions require the authorized role and a business-continuity check (FLR-01 Action 1).

Required field	Learner entry
Evidence preserved	Step 2 of 3 — Preserve evidence, 08:52 ET† (FLR-01 Action 2; EVID-01). Items: A-01 (file storage, sharing, and FileAccessed record), A-02 (ticket and user statement), A-03 (message: original left unaltered in the mailbox and recorded by Message ID for SOC collection through the approved submission procedure), A-04 (sign-in and risk records), A-05 (posture extract); time window 09/03/2026 08:11–08:44 ET plus link creation 08/28/2026. Location: restricted evidence repository linked to SIR-00517†. Integrity: originals stored unchanged; nothing deleted, edited, annotated, exported, or forwarded; redacted working copies derived separately (Component 4). Defender incident/alert IDs, Entra request/correlation IDs, and Purview audit record IDs are not in the packet; they were requested from the SOC, not invented.
SOC escalation	Step 3 of 3 — Escalate (FLR-01 Action 3; IR-01.B immediate). **WT-00517-SOC†** — 09/03/2026 08:55 ET† via restricted ServiceNow task under SIR-00517†; acknowledged 09:00 ET† by SOC Tier 2 Triage queue† (new owner). Full summary below.
Unresolved questions	1. Who controlled the 08:29 ET session and the 08:32 ET file activity? 2. Do sessions or tokens issued at 08:29 ET remain active? (The 08:36 ET block applies to a later attempt.) 3. What is the actual link target? The packet records only the link shown; Tier 1 did not open it. 4. Did other workforce members receive or act on the same message? 5. Why did the 08:29 ET sign-in succeed when the reporter states no Authenticator prompt was approved? A-05 shows CA-CLINICAL-MFA did not apply; whether MFA was required or satisfied for that sign-in is not shown. 6. Were any authentication methods or account settings changed after 08:29 ET?

FLR-01 action record (actor, action, timestamp, SOP criterion, result)

Time (ET)	Actor	Action	SOP criterion	Result
08:46†	Tier 1	Read the full ticket and evidence packet A–D before any action	Assignment Step 1; FLR-01 entry criteria	Phishing, account, and file concerns identified
08:47†	Tier 1	Opened and reviewed the HIPAA Compliance Checklist before any processing decision	Checklist A–D	Possible ePHI involvement noted for PRIV-01
08:48†	Tier 1	Opened restricted security incident SIR-00517†	FLR-01 Action 1; Checklist A.1	Opened
08:49†	Tier 1	Stopped reporter interaction with the message; gave downtime / alternate-access route	FLR-01 Action 1; care-continuity checks	Reporter confirmed†
08:52†	Tier 1	Preserved A-01 to A-05 unchanged in the restricted repository	FLR-01 Action 2; EVID-01	Preserved
08:55†	Tier 1	Warm transfer to SOC (WT-00517-SOC†)	FLR-01 Action 3; IR-01.B	Acknowledged 09:00†
09:03†	Tier 1	Warm transfer to IAM for authorized session revocation / password reset and CA exception review (WT-00517-IAM†)	FLR-01 Action 1; IR-01.B; Check 1 Fail	Acknowledged 09:07†; result pending IAM
Not performed	—	Account disablement, session revocation, password reset, risk confirmation or dismissal	FLR-01 Action 1 (authorized role and business-continuity check required)	Requested from IAM within SOC scope

EVID-01 evidence record

Evidence ID	Source	Time range	Repository	Integrity note
A-01	SharePoint storage / sharing configuration and Purview FileAccessed event (Evidence D)	Link created 08/28/2026; FileAccessed 09/03/2026 08:32	Restricted evidence repository, SIR-00517†	Original unchanged; Purview record ID not in packet (requested)
A-02	Ticket TKT-00517 intake and reporter statement	Opened 09/03/2026 08:44; reported events ~08:17	Same	Original contains patient identifiers entered by the reporter; preserved unchanged; only the redacted copy is used here
A-03	Suspicious message excerpt (Evidence A)	Received 09/03/2026 08:14	Original left in mailbox; recorded by Message ID	Not forwarded, deleted, or annotated; SOC to collect via approved submission
A-04	Microsoft Entra sign-in extract (Evidence B)	09/03/2026 08:11–08:36	Restricted evidence repository, SIR-00517†	Original unchanged; request/correlation IDs not in packet (requested)
A-05	Account security posture extract (Evidence C)	Extract timestamp not shown	Same	Original unchanged; missing evidence timestamp recorded as a gap

Warm-transfer summary WT-00517-SOC† — Contoso Health Security Operations Center (SOC)

Format: 03 Warm-Transfer Summary Template. † = simulated value on the 09/03/2026 training timeline; all times ET.

Routing header

Field	Entry
To	Contoso Health Security Operations Center (SOC)
From	Tier 1 Healthcare IT Support
Ticket	TKT-00517
Transfer timestamp	09/03/2026 08:55 ET†
Approved channel / record ID	Restricted ServiceNow security incident task WT-00517-SOC† under SIR-00517†. Task short description: “TKT-00517 suspected phishing credential compromise — SOC triage”
Urgency	Immediate — IR-01.B (credentials entered; risky sign-in). Ticket priority P2.

Summary body

Required field	Entry
Anonymized incident description	An Attending Physician (Emergency Medicine) reports that at about 08:17 ET an email impersonating “Epic Support” was opened, the link was selected, and the work username and password were entered; the page then stopped responding. The reporter states no Authenticator prompt was approved and is working in Boston with no travel this week. The Affected Workforce Account then shows a successful sign-in from an unfamiliar location. The account is associated with a PHI-bearing SharePoint file (Artifact A-01) that has a file-access event in the same window.
Observed signals / check outcomes	1. 08:14 — Message received: display name “Epic Support”; sender epic-support@access-review[.]example; subject “Urgent: verify clinical access”; link shown hxxps://verify-access[.]example/contoso; Message ID <synthetic-00517@access-review.example> (A-03). 2. ~08:17 — Reporter states credentials were entered on the linked page (A-02). 3. 08:11 — Success, 192.0.2.18 / Boston, MA, device CH-CLIN-044, risk None (A-04); consistent with the reporter’s statement. 4. 08:29 — Success, 198.51.100.24 / Phoenix, AZ, “Unfamiliar sign-in properties,” device ID unavailable (A-04). 5. 08:32 — Purview FileAccessed on Artifact A-01 by the Affected Workforce Account from 198.51.100.24 (A-01); the event does not establish who controlled the session. 6. 08:36 — Failure 50053, 198.51.100.24 / Phoenix, AZ, “High-confidence risk block” (A-04). 7. A-05 — CA-CLINICAL-MFA did not apply; the account remains in CA-TEMP-EXCEPTION with a blank end date (routed to IAM separately). Tier 1 category: Category 2 suspected credential compromise via Category 1 phishing; Category 4 question open. No severity assigned by Tier 1.
Actions already taken	Actor for all: Tier 1 Healthcare IT Support. 08:46† ticket and evidence read in full; 08:48† SIR-00517† opened; 08:49† Attending Physician instructed to stop interacting with the message (not to reopen, reply to, forward, or delete it; not to add patient details to the ticket) and given the approved downtime / alternate-access route; 08:52† evidence preserved under EVID-01. Not performed by Tier 1: account disablement, session revocation, password reset, risk confirmation or dismissal (authorized role and business-continuity check required, FLR-01).
Evidence preserved	A-01 (file sharing and audit record), A-02 (ticket and statement), A-03 (message; original left unaltered in the mailbox and recorded by Message ID; not forwarded), A-04 (sign-in extract), A-05 (posture extract). Originals unchanged in the restricted evidence repository under SIR-00517†. No attachments or unredacted content in this transfer. Not in the packet: Defender incident/alert IDs, Entra request/correlation IDs, Purview record IDs.
Specific action requested	1. Triage and investigate under IR-01.B; determine containment scope, including whether sessions or tokens from the 08:29 ET sign-in remain active, and direct IAM’s authorized session revocation and password reset (WT-00517-IAM† to follow). 2. Collect the original message through the approved submission procedure; confirm the actual link target; identify other recipients or clicks of the same Message ID or URL. 3. Correlate Defender and Entra signals; add incident/alert and request IDs to SIR-00517†. 4. Share session-attribution findings for the 08:32 ET file event with the HIPAA Privacy & Compliance Office (PRIV-01 transfer runs in parallel).
Unresolved question	Was the 08:29 ET session, and the 08:32 ET file activity, controlled by the Attending Physician or by another party? Tier 1 has not determined this and has not classified severity.

Required field	Entry
Acknowledgment / new owner	SOC Tier 2 Triage queue† — 09/03/2026 09:00 ET†

Pre-send verification — completed 08:54 ET†

- ✔ Exact timestamp, time zone, and ticket number are present.
- ✔ Receiving function and approved channel match the escalation reference.
- ✔ Every statement is supported by an evidence ID or check outcome.
- ✔ Patient identifiers, workforce identifiers, usernames, and PHI-bearing filenames are replaced or removed under program policy. (Role labels and Artifact A-01 used; no MRN, DOB, or names.)
- ✔ Subject line, message body, attachment name, metadata, and screenshots were checked. (Short description checked; no attachments; no chat used.)
- ✔ No breach, notification, severity, or actual-access determination is asserted by Tier 1.

2. Component 2 - Cloud Security Verification

The three basic checks were run read-only on the supplied Entra and Purview extracts at 08:56–09:01 ET† (Basic Cloud Security Check Procedure v1.0). Configuration and log signals support routing only; they do not establish compromise, unauthorized access, or a HIPAA breach. “Observed state” is the post-incident state; items the packet does not show are labeled “not shown.”

Check	Pre-incident state	Observed state	Outcome	Evidence / routing
Sign-in / policy	08:11 ET Success from 192.0.2.18 / Boston, MA on CH-CLIN-044; risk signal None; consistent with the reporter’s location (A-04, A-02). Intended policy: CA-CLINICAL-MFA. A-05 says the user “remains” in CA-TEMP-EXCEPTION; when membership began and any documented justification are not shown.	08:29 ET Success from 198.51.100.24 / Phoenix, AZ; “Unfamiliar sign-in properties”; device ID unavailable. 08:36 ET Failure 50053, same IP, “High-confidence risk block” (A-04). CA-CLINICAL-MFA did not apply; account remains in CA-TEMP-EXCEPTION; exception end date blank (A-05). Not shown in the extract: application, authentication requirement, per-sign-in CA result, risk level.	**Fail** (exception not documented as current; intended policy did not apply) **Review** (risky sign-in cannot be resolved at Tier 1)	A-04, A-05, A-02. Fail → Identity & Access Management Operations (WT-00517-IAM†). Review → Contoso Health SOC (WT-00517-SOC†, opened in Component 1).
MFA / authentication methods	Microsoft Authenticator registered; no FIDO2 security key registered (A-05). Registration date not shown.	No change shown (A-05). A-05 carries no evidence timestamp, so it cannot be placed before or after 08:29 ET. Reporter states no Authenticator prompt was approved (A-02). A registered method does not prove MFA was required or satisfied for the 08:29 ET sign-in.	**Pass** — registration only (enforcement not established; see Check 1)	A-05, A-02. No remediation transfer for registration. FIDO2 absence recorded as an observation: no requirement in the supplied baseline. Method-change and enforcement questions included in WT-00517-IAM†.

Check	Pre-incident state	Observed state	Outcome	Evidence / routing
Audit visibility	Not shown in the packet (no pre-incident audit-configuration evidence).	Entra sign-in events and Microsoft Purview audit events are available for the relevant window: sign-ins 08:11–08:36 ET; FileAccessed 08:32 ET (A-05, A-04, A-01). Not supplied: sharing-audit events for the 08/28/2026 link creation and any anonymous-link use; Defender alert IDs; Entra request IDs; Purview record IDs. Tier 1's own Purview search role (Audit Logs / View-Only Audit Logs) is not stated: not independently testable, and not a failure.	**Pass**	A-05. M365 Purview Audit Administration: not triggered (evidence available to authorized roles). Missing records requested from approved owners via WT-00517-SOC† and WT-00517-IG†.

Cloud-security warm-transfer reference(s): WT-00517-IAM† — Identity & Access Management Operations — 09/03/2026 09:03 ET† (Check 1 Fail). WT-00517-SOC† — Contoso Health SOC — 08:55 ET† (Check 1 Review; opened in Component 1). M365 Purview Audit Administration — not triggered: A-05 shows Entra sign-in and Purview audit events are available.

Warm-transfer summary WT-00517-IAM† — Identity & Access Management Operations

Format: 03 Warm-Transfer Summary Template. † = simulated value on the 09/03/2026 training timeline; all times ET.

Routing header

Field	Entry
To	Identity & Access Management Operations
From	Tier 1 Healthcare IT Support
Ticket	TKT-00517
Transfer timestamp	09/03/2026 09:03 ET†
Approved channel / record ID	Restricted ServiceNow security incident task WT-00517-IAM† under SIR-00517†. Task short description: "TKT-00517 identity containment and Conditional Access exception review"
Urgency	Immediate for containment — IR-01.B ("IAM containment/remediation under authorized role"); exception remediation per Check 1 Fail. Ticket priority P2.

Summary body

Required field	Entry
Anonymized incident description	The Affected Workforce Account (Attending Physician, Emergency Medicine) is under SOC investigation (WT-00517-SOC†) after the reporter entered credentials on a suspected phishing page; a successful sign-in from an unfamiliar location followed. Tier 1 cloud security checks found that the intended clinical MFA Conditional Access policy did not apply and that the account remains in a temporary exception with no end date.

Required field	Entry
Observed signals / check outcomes	1. Check 1 — Fail + Review: 08:29 ET Success, 198.51.100.24 / Phoenix, AZ, “Unfamiliar sign-in properties,” device ID unavailable; 08:36 ET Failure 50053, “High-confidence risk block” (A-04). CA-CLINICAL-MFA did not apply; account remains in CA-TEMP-EXCEPTION; exception end date blank (A-05). Application, authentication requirement, and per-sign-in CA result not shown. 2. Check 2 — Pass (registration only): Microsoft Authenticator registered; no FIDO2 key registered (A-05). Registration does not show MFA was required or satisfied at 08:29 ET; A-05 has no evidence timestamp. Reporter states no Authenticator prompt was approved (A-02). 3. Check 3 — Pass: Entra sign-in and Purview audit events available (A-05); Purview Audit Administration not triggered.
Actions already taken	Actor for all: Tier 1 Healthcare IT Support. 08:48† SIR-00517† opened; 08:49† reporter instructed to stop interacting with the message and given the approved downtime / alternate-access route; 08:52† evidence preserved; 08:55† SOC transfer (acknowledged 09:00†); 08:56–09:01† Checks 1–3 run read-only. Tier 1 made no account, authentication-method, group, or policy change.
Evidence preserved	A-04 (sign-in extract), A-05 (posture extract), A-02 (reporter statement): restricted evidence repository under SIR-00517†. No attachments in this transfer.
Specific action requested	1. Within the SOC’s containment scope and under the authorized role (Authentication Administrator; Privileged Authentication Administrator where required): revoke the account’s sessions and reset its password after the business-continuity check. The account belongs to an Emergency Medicine physician working today who has the approved downtime / alternate-access route. Record the result in SIR-00517†. 2. Review the account’s CA-TEMP-EXCEPTION membership: is there a documented, current justification and end date? Remediate under the Conditional Access Administrator or assigned security role as authorized, and confirm the result. 3. Confirm whether any authentication method was added or changed on or after 08:29 ET. 4. For the assigned policy owner: no FIDO2 key is registered; the supplied baseline sets no requirement, so this is an observation, not a Tier 1 finding.
Unresolved question	Is the account’s CA-TEMP-EXCEPTION membership authorized and current, and was MFA required or satisfied for the 08:29 ET sign-in?
Acknowledgment / new owner	IAM Operations — Identity Remediation queue† — 09/03/2026 09:07 ET†

Pre-send verification — completed 09:02 ET†

- ✔ Exact timestamp, time zone, and ticket number are present.
- ✔ Receiving function and approved channel match the escalation reference.
- ✔ Every statement is supported by an evidence ID or check outcome.
- ✔ Patient identifiers, workforce identifiers, usernames, and PHI-bearing filenames are replaced or removed under program policy. (Role labels only; no username or email.)
- ✔ Subject line, message body, attachment name, metadata, and screenshots were checked. (Short description checked; no attachments; no chat used.)
- ✔ No breach, notification, severity, or actual-access determination is asserted by Tier 1.

3. Component 3 - Data Security Audit

The shared clinical file was audited read-only at 09:04–09:08 ET† against the Data Security Safeguards Reference. The configured control and the observed evidence were evaluated separately: service encryption does not make an over-broad sharing link acceptable. Tier 1 did not open, download, or change Artifact A-01, its link, or any permission (action boundary; M365-01).

Aspect	Control examined	Outcome	Evidence	Routing
Storing	Encryption and approved location	**Pass**	A-01: Microsoft 365 service encryption at rest is active; no encryption exception shown. Location: SharePoint site “ED Case Conference” / Shared Documents / Week 35 in the Contoso Health tenant. Approved-site and retention context and any sensitivity-label or DLP requirement are not shown in the packet; no label requirement was invented.	Not triggered for encryption. Approved-location and retention confirmation requested in WT-00517-IG†.
Sharing	Link scope and external sharing	**Fail**	A-01: “Anyone with the link” link created 08/28/2026; expiration none; password none. Link creator, recipients, and the site’s sharing policy not shown. Baseline: Data Security Safeguards Reference §2 treats an Anyone link for clinical PHI as a governance finding.	Information Governance (WT-00517-IG†) and HIPAA Privacy & Compliance Office (WT-00517-PRIV†); PRIV-01.B; M365-01. No sharing change by Tier 1.
Accessing	Permissions and audit events	**Review**	A-01: Purview FileAccessed 09/03/2026 08:32 ET by the Affected Workforce Account from 198.51.100.24, the same IP as the 08:29 ET unfamiliar sign-in (A-04). The event records service activity for an identity/session; it does not establish the human actor, viewing, or breach status. Direct, group, guest, and inherited permissions and the Purview record ID are not shown.	SOC for session attribution (WT-00517-SOC†); HIPAA Privacy & Compliance Office, PRIV-01.A (WT-00517-PRIV†); permissions review in WT-00517-IG†.

TIMING NOTE The reporter statement places the collaboration “yesterday” (09/02/2026); the scenario intake described it as “last week”; the Anyone link was created 08/28/2026. The packet contains no access events before 09/03/2026 08:32 ET. Recorded as stated and not reconciled at Tier 1.

Warm-transfer summary WT-00517-IG† — Information Governance

Format: 03 Warm-Transfer Summary Template. † = simulated value on the 09/03/2026 training timeline; all times ET.

Routing header

Field	Entry
To	Information Governance
From	Tier 1 Healthcare IT Support
Ticket	TKT-00517
Transfer timestamp	09/03/2026 09:10 ET†
Approved channel / record ID	Restricted ServiceNow security incident task WT-00517-IG† under SIR-00517†. Task short description: “TKT-00517 shared clinical file — Anyone-link governance finding”

Field	Entry
Urgency	Ticket priority P2; PRIV-01.B trigger. The runbooks set no separate time frame for this transfer; sent in parallel with the PRIV-01 privacy transfer.

Summary body

Required field	Entry
Anonymized incident description	A PHI-bearing emergency-department case-review file (Artifact A-01) in the “ED Case Conference” SharePoint site is associated with an account under SOC investigation for suspected credential compromise (WT-00517-SOC†). Tier 1’s data security audit found an “Anyone with the link” sharing link on the file with no expiration and no password.
Observed signals / check outcomes	1. Storing — Pass: Microsoft 365 service encryption at rest active; no encryption exception (A-01). Approved-site and retention context and any label requirement not shown. 2. Sharing — Fail: “Anyone with the link” link created 08/28/2026; expiration none; password none (A-01). Creator, recipients, and the site sharing policy not shown. Governance finding under Data Security Safeguards Reference §2; PRIV-01.B. 3. Accessing — Review: Purview FileAccessed 09/03/2026 08:32 ET by the Affected Workforce Account from 198.51.100.24 (A-01), the same IP as the 08:29 ET unfamiliar sign-in (A-04). Does not establish the human actor. Direct, group, guest, and inherited permissions not shown. 4. Reporter states the file was reviewed with a second physician on 09/02/2026 (A-02).
Actions already taken	Actor for all: Tier 1 Healthcare IT Support. 08:55† SOC transfer (acknowledged 09:00†); 09:03† IAM transfer (acknowledged 09:07†); 09:04–09:08† three-aspect audit, read-only. Tier 1 did not open, download, or change the file, the link, or any permission.
Evidence preserved	A-01 (sharing configuration and audit event), A-04 (sign-in extract), A-02 (reporter statement): restricted evidence repository under SIR-00517†. The link URL and file content are not included.
Specific action requested	1. Per M365-01, preserve current permissions, sharing-link details, guest membership, and related audit events before any remediation. 2. Assess the Anyone link against the governance baseline and the site’s sharing policy, and authorize remediation. 3. Provide sharing-audit evidence (link creator and record ID; any anonymous-link access events since 08/28/2026) to SIR-00517† for the SOC and the Privacy Office. 4. Confirm the site and library are an approved location with the correct retention context, and whether any sensitivity-label or DLP requirement applies.
Unresolved question	Does the Anyone link on Artifact A-01 conform to the site’s sharing policy and the governance baseline, and who created it?
Acknowledgment / new owner	Information Governance — M365 Sharing Review queue† — 09/03/2026 09:16 ET†

Pre-send verification — completed 09:09 ET†

- ✔ Exact timestamp, time zone, and ticket number are present.
- ✔ Receiving function and approved channel match the escalation reference.
- ✔ Every statement is supported by an evidence ID or check outcome.
- ✔ Patient identifiers, workforce identifiers, usernames, and PHI-bearing filenames are replaced or removed under program policy. (Filename replaced with Artifact A-01; no link URL.)

- ✔ Subject line, message body, attachment name, metadata, and screenshots were checked. (Short description checked; no attachments; no chat used.)
- ✔ No breach, notification, severity, or actual-access determination is asserted by Tier 1.

4. Component 4 - PHI Redaction

PHI Redaction Procedure and Verification Checklist v1.0 was applied to every artifact captured in Components 1–3 (ticket-note excerpts, portal views transcribed as text, and diagnostic log lines) and to every warm-transfer summary, at 09:11–09:18 ET†.

- **Step 1, approved copy.** Work was done on redacted working copies; originals are preserved unchanged in the restricted evidence repository (EVID-01).
- **Step 2, inventory.** Visible and hidden identifiers were inventoried: text, filenames, headers, subject lines, metadata, comments, alt text, hyperlinks, embedded objects.
- **Step 3, consistent substitution.** The substitution key below was applied identically across all artifacts and all four transfers.
- **Step 4, images.** No image screenshots were captured; portal views are recorded as text transcriptions, so irreversible image redaction does not apply.
- **Step 5, re-verification.** Each artifact was re-searched for patient name terms, 8-digit MRN strings and “MRN” / chart-number labels, date-of-birth formats, the reporter’s name, the workforce username/email and domain, and the original filename. Outcomes are recorded below.

Substitution key (original values are held only in the restricted record)

Data type	Where it appeared	Replacement applied
Patient name	A-02 reporter statement; A-01 filename	Patient A
Medical record number	A-02 reporter statement	[MRN REMOVED]
Date of birth	A-02 reporter statement	[DOB REMOVED]
Provider / workforce name (reporter)	A-02 reporter field	Attending Physician
Second physician	A-02 reporter statement (not named in the packet)	“second physician”; no name present to remove
Username / email	A-02 affected identity; A-01 “affected account”	Affected Workforce Account
PHI-bearing filename / URL path	A-01 file name (contains the patient name)	Artifact A-01 (site / library / folder kept; it carries no identifiers)

Per-artifact verification

Artifact ID	Original data types	Substitutions / removals	Hidden-data checks	Final outcome
A-01 Shared clinical file record (Evidence D)	Patient name embedded in the filename; workforce account reference	Filename → Artifact A-01; account → Affected Workforce Account	Filename ✓; URL display text and target: no hyperlink retained ✓; metadata ✓; alt text N/A (text) ✓; hidden text ✓	**Clean**

Artifact ID	Original data types	Substitutions / removals	Hidden-data checks	Final outcome
A-02 Ticket intake and reporter statement	Patient name; MRN; DOB; provider name; workforce email; reporter location (kept: workforce location, not a patient identifier)	Patient A; [MRN REMOVED]; [DOB REMOVED]; Attending Physician; Affected Workforce Account	Ticket title / subject ✓; digit-string and MRN-label search ✓; date-format search ✓; attachment names: none ✓	**Clean**
A-03 Suspicious message excerpt (Evidence A)	No patient identifiers; external sender (not workforce); subject; displayed link; Message ID	None required. Sender and link defanged for safe handling (not a redaction); Message ID kept as the preservation key	Subject line ✓; link display vs. target (target not in packet) ✓; headers: recipient not shown ✓	**Clean**
A-04 Entra sign-in extract (log lines)	IP addresses, locations, device name CH-CLIN-044; no user column	None required: not patient identifiers; kept as minimum necessary for SOC/IAM; account referenced as Affected Workforce Account	Every log-line field ✓; no username/UPN present ✓	**Clean**
A-05 Posture extract (Evidence C)	Policy names; authentication-method types; no personal identifiers	None required	All fields ✓	**Clean**
WT-00517-SOC†	Role labels; defanged indicators; evidence IDs	Substitution key applied	Short description / subject, body, attachment names (none), chat fields (none used) ✓	**Clean** (pre-send 08:54†; re-verified 09:12†)
WT-00517-IAM†	Role labels; policy names; evidence IDs	Substitution key applied	Same checks ✓	**Clean** (pre-send 09:02†; re-verified 09:14†)
WT-00517-IG†	Role labels; Artifact A-01; evidence IDs	Substitution key applied	Same checks; no link URL ✓	**Clean** (pre-send 09:09†; re-verified 09:16†)
WT-00517-PRIV†	Role labels; Patient A; data types only (no values)	Substitution key applied	Same checks ✓ (drafted in Component 5)	**Clean** (pre-send 09:25†)
CR-00517 This Case Report (DOCX and PDF)	All of the above	Substitution key applied throughout	Document properties, header / footer, comments, tracked changes, hidden text, hyperlinks, embedded objects; exported PDF reopened, text-searched, and visually inspected ✓	**Clean** (09:42 ET†)

Reviewer: Tier 1 Healthcare IT Support. Outcomes recorded 09:18 ET† (A-01 to A-05 and the SOC, IAM, and IG transfers), 09:25 ET† (privacy transfer), and 09:42 ET† (final export).

IMPORTANT Incident-record redaction is an internal minimum-necessary control. These artifacts are not claimed to be HIPAA de-identified; the Safe Harbor and Expert Determination methods were not applied.

5. Component 5 - HIPAA Follow-and-Escalate

Required field	Learner entry
Checklist version and completion time	HIPAA Compliance Checklist, LC 5 learner attachment (no version number shown on the document). Opened and reviewed 08:47 ET†, before any processing decision; completed 09:23 ET†. Results are in the table below.
Applicable SOP/runbook criterion	**IR-01.B: met.** Threshold: “Credentials entered, unexpected MFA interaction, risky sign-in, or suspected session misuse.” Credentials entered (A-02) and risky sign-in (A-04). **IR-01.C: met.** Threshold: “Possible ePHI repository or clinical file involvement.” PHI-bearing clinical file Artifact A-01 (A-01, A-02); apply PRIV-01 in parallel. **PRIV-01.A: met.** Threshold: “Possible ePHI involvement plus suspected credential/session misuse or unauthorized file-access signal.” A-01 file-access event in the suspicious session window. **PRIV-01.B: met.** Threshold: “Over-broad sharing, guest access, anonymous link, or permissions drift affecting PHI.” Anyone link with no expiration or password (A-01). **Not met:** IR-01.A (credentials were entered and a risk signal exists); PRIV-01.C (PHI is involved per A-01 and A-02). **Also applied:** EVID-01 (evidence), M365-01 (shared-file governance), PRIV-02 (determination reserved to the privacy function).
Documented facts supporting routing	Component 1: Category 2 suspected credential compromise via Category 1 phishing. Credentials entered ~08:17 ET (A-02, A-03); 08:29 ET unfamiliar successful sign-in from 198.51.100.24 (A-04); 08:36 ET high-confidence risk block (A-04). Component 2: Check 1 Fail (CA-CLINICAL-MFA did not apply; CA-TEMP-EXCEPTION end date blank, A-05) and Review; Check 2 Pass (registration only); Check 3 Pass. Component 3: Storing Pass; Sharing Fail (Anyone link since 08/28/2026, no expiration or password, A-01); Accessing Review (FileAccessed 08:32 ET from 198.51.100.24, A-01). Component 4: all five exhibits and all four transfers verified Clean; identifiers withheld from handoffs.
SOP-fit result	**Escalation required.** Tier 1 followed FLR-01 and EVID-01 for containment and evidence, but the ticket cannot be resolved within a Tier 1 runbook. IR-01.B requires an immediate SOC transfer and IAM containment under an authorized role. IR-01.C requires PRIV-01 in parallel. PRIV-01.A and PRIV-01.B require Privacy Office review and Information Governance review. PRIV-02 reserves impermissible-use, breach, and notification determinations to the designated privacy function.
Unresolved privacy question	**Ambiguity flagged (stated, not decided):** The 08:32 ET FileAccessed event on Artifact A-01 was recorded for the Affected Workforce Account from the same IP as an unfamiliar successful sign-in that followed credential entry. The file has also carried an Anyone link with no expiration or password since 08/28/2026. The record does not establish who controlled the session, whether content was viewed or acquired, or whether the link was used by anyone else. Decision needed from the HIPAA Privacy & Compliance Office: do these facts constitute an impermissible use or disclosure of Patient A’s PHI, and which PRIV-02 assessment path applies? Secondary: the supplied HIPAA SOPs and Pre-Approved Runbooks v1.0 show an effective date of 09/04/2026, one day after this ticket. Tier 1 applied them as the controlling training baseline; the Office is asked to confirm the governing version.
Privacy/compliance warm-transfer	**WT-00517-PRIV†**, 09/03/2026 09:26 ET†, to the HIPAA Privacy & Compliance Office, via a restricted ServiceNow privacy incident task under SIR-00517†. Acknowledged 09:31 ET† by the Privacy Incident Intake queue†. Full summary below.
Prohibited determinations check	**Confirmed: no breach, notification, or actual-access conclusion made.** No impermissible-use, disclosure, severity, or exposure conclusion appears in this report or its four transfers. Statements are limited to recorded signals (“event recorded,” “not established”) and questions routed to the owning function.

HIPAA Compliance Checklist results

Item	Checklist requirement	Result	Basis
A.1	Suspected or known security incident identified and incident record opened	Met	SIR-00517† opened 08:48†
A.2	Documented response procedure and assigned security function identified	Met	FLR-01 v1.0 / IR-01; SOC owns (09:00†)
A.3	Authorized containment and mitigation status recorded	Met	Component 1 action record; IAM result pending IAM confirmation
A.4	Security incident and outcome documentation preserved	Met	EVID-01 record, A-01 to A-05
B.1	System, repository, and data type named without unnecessary PHI	Met	Microsoft 365 SharePoint, “ED Case Conference” site, Artifact A-01. Per reporter: patient name, MRN, DOB, and ED case details for one patient (values withheld)
B.2	Evidence distinguishes possible access from confirmed acquisition or viewing	Met	08:32 ET FileAccessed described as service-recorded activity only
B.3	Minimum-necessary information in handoffs; access limited to authorized roles	Met	Component 4; restricted ServiceNow tasks only
B.4	Privacy/compliance trigger in PRIV-01 evaluated	Met	PRIV-01.A and .B met; .C not met
D.1	Exact timestamps, ticket number, evidence IDs, action status, and receiving owner recorded	Met	Components 1–5 and Section 6
D.2	Approved SOP/runbook criterion cited	Met	IR-01.B/.C; PRIV-01.A/.B; PRIV-02
D.3	Unresolved question stated without a breach or notification conclusion	Met	Unresolved privacy question above
D.4	No PHI or workforce identifier outside the approved restricted record beyond what is necessary	Met	Component 4: all Clean

Section C — questions reserved for the designated privacy function

Question reserved for designated privacy function	Tier 1 entry	Available evidence (facts only; not scored)
Was there an impermissible use or disclosure under the Privacy Rule?	Unresolved - cite facts only	Credentials entered (A-02); 08:29 ET unfamiliar successful sign-in (A-04); 08:32 ET FileAccessed from the same IP (A-01); Anyone link since 08/28/2026 (A-01).
Does an exception to the definition of breach apply?	Unresolved	—
Is the four-factor breach risk assessment required or will notification proceed without it?	Unresolved	—

Question reserved for designated privacy function	Tier 1 entry	Available evidence (facts only; not scored)
What are the nature/extent of PHI, unauthorized recipient, actual acquisition/viewing, and mitigation?	Provide available evidence; do not score	**Nature/extent:** per the reporter, one patient (Patient A): name, MRN, DOB, and ED case details. Tier 1 did not open the file. **Recipient:** not established. The 08:29 ET session from 198.51.100.24 is unattributed; anonymous-link use not reviewed (no events supplied). **Acquisition/viewing:** not established. One FileAccessed event; no download, sync, or print events in the packet. **Mitigation:** 08:36 ET risk block recorded by Entra; session revocation / password reset requested (WT-00517-IAM†, acknowledged, result pending); link remediation requested (WT-00517-IG†, acknowledged, pending).
Are individual, HHS, media, contractual, or state-law notifications required?	Unresolved	—

Warm-transfer summary WT-00517-PRIV† — HIPAA Privacy & Compliance Office

Format: 03 Warm-Transfer Summary Template. † = simulated value on the 09/03/2026 training timeline; all times ET.

Routing header

Field	Entry
To	HIPAA Privacy & Compliance Office
From	Tier 1 Healthcare IT Support
Ticket	TKT-00517
Transfer timestamp	09/03/2026 09:26 ET†
Approved channel / record ID	Restricted ServiceNow privacy incident task WT-00517-PRIV† under SIR-00517† (privacy-restricted). Task short description: “TKT-00517 PRIV-01 review — possible ePHI involvement”
Urgency	In parallel with the SOC investigation — IR-01.C; PRIV-01.A and PRIV-01.B met. Ticket priority P2.

Summary body

Required field	Entry
Anonymized incident description	An Attending Physician (Emergency Medicine) reports entering work credentials on a page linked from an email impersonating “Epic Support.” The Affected Workforce Account is associated with a PHI-bearing emergency-department case-review file in SharePoint (Artifact A-01). Per the reporter, the file contains details for one patient (Patient A), including name, MRN, and date of birth (values withheld). A file-access event was recorded on Artifact A-01 during the suspicious sign-in window, and the file carries an Anyone link.

Required field	Entry
Observed signals / check outcomes	1. Component 1: Category 2 suspected credential compromise via Category 1 phishing. Credentials entered ~08:17 ET (A-02, A-03); 08:29 ET successful sign-in from 198.51.100.24 / Phoenix, AZ, “Unfamiliar sign-in properties” (A-04); 08:36 ET high-confidence risk block from the same IP (A-04). 2. Component 2: Check 1 Fail (CA-CLINICAL-MFA did not apply; CA-TEMP-EXCEPTION end date blank, A-05); Check 2 Pass (registration only); Check 3 Pass. 3. Component 3: Storing Pass; Sharing Fail (Anyone link created 08/28/2026, no expiration or password, A-01); Accessing Review (FileAccessed 08:32 ET from 198.51.100.24, A-01; service-recorded activity only). 4. Component 4: all exhibits and transfers verified Clean; identifiers withheld here. 5. Checklist outcome: A 4/4 met; B 4/4 met; C all five reserved questions entered as “Unresolved” (facts provided, not scored); D 4/4 met. 6. SOP fit: escalation required. IR-01.B, IR-01.C, PRIV-01.A, and PRIV-01.B met; IR-01.A and PRIV-01.C not met; PRIV-02 reserves the determination.
Actions already taken	Actor for all: Tier 1 Healthcare IT Support. 08:48† SIR-00517† opened; 08:49† reporter instructed; 08:52† evidence preserved; 08:55† SOC transfer (acknowledged 09:00†); 09:03† IAM transfer requesting session revocation and password reset (acknowledged 09:07†; result pending IAM); 09:10† Information Governance transfer (acknowledged 09:16†); 09:18† redaction verification complete; 09:23† checklist complete. Tier 1 did not open, download, or reproduce Artifact A-01 content.
Evidence preserved	A-01 to A-05 in the restricted evidence repository under SIR-00517†. The reporter’s original ticket text contains Patient A’s identifiers; it is preserved unchanged as A-02 and is not reproduced here. No attachments in this transfer.
Specific action requested	Determine the privacy implications, the risk-assessment path, and any notification obligations under PRIV-02. Coordinate with the SOC on session attribution (WT-00517-SOC†) and with Information Governance on the link-use audit (WT-00517-IG†).
Unresolved question	**Ambiguity flagged:** The 08:32 ET file-access event on Artifact A-01 was recorded for the Affected Workforce Account from the same IP as an unfamiliar successful sign-in that followed credential entry. The file has also carried an Anyone link with no expiration or password since 08/28/2026. The record does not establish who controlled the session, whether content was viewed or acquired, or whether the link was used by anyone else. Decision needed: do these facts constitute an impermissible use or disclosure, and which PRIV-02 assessment path applies? Please also confirm the governing runbook version: v1.0 shows an effective date of 09/04/2026, one day after this ticket.
Acknowledgment / new owner	HIPAA Privacy & Compliance Office — Privacy Incident Intake queue† — 09/03/2026 09:31 ET†

Pre-send verification — completed 09:25 ET†

- ✔ Exact timestamp, time zone, and ticket number are present.
- ✔ Receiving function and approved channel match the escalation reference.
- ✔ Every statement is supported by an evidence ID or check outcome.
- ✔ Patient identifiers, workforce identifiers, usernames, and PHI-bearing filenames are replaced or removed under program policy. (Patient A and data types only; no values.)
- ✔ Subject line, message body, attachment name, metadata, and screenshots were checked. (Short description checked; no attachments; no chat used.)
- ✔ No breach, notification, severity, or actual-access determination is asserted by Tier 1.

6. Case Summary

Incident facts: On 09/03/2026 at 08:14 ET, an email displaying the name “Epic Support” from an external domain was received by the Affected Workforce Account. The Attending Physician (Emergency Medicine) reports opening it at about 08:17 ET, selecting the link, and entering a work username and password, and states that no Authenticator prompt was approved and no travel occurred. Entra recorded a successful Boston sign-in at 08:11 ET, a successful sign-in flagged “unfamiliar sign-in properties” from 198.51.100.24 (Phoenix, AZ) at 08:29 ET, and a high-confidence risk block from that address at 08:36 ET. Purview recorded a FileAccessed event on PHI-bearing file Artifact A-01 by the account from the same address at 08:32 ET. CA-CLINICAL-MFA did not apply; the account remains in CA-TEMP-EXCEPTION with a blank end date. Artifact A-01 has had an Anyone link without expiration or password since 08/28/2026.

Containment and evidence status: Tier 1 opened restricted incident SIR-00517† (08:48†), stopped the reporter’s interaction with the message and gave the approved downtime route (08:49†), and immediately engaged the SOC (08:55†) and IAM (09:03†). Session revocation and password reset were requested from IAM under the authorized role; IAM acknowledged at 09:07† and the execution result is pending IAM confirmation. Tier 1 made no account, policy, sharing, or permission change. Evidence A-01 to A-05 is preserved unchanged in the restricted evidence repository; the phishing message remains in place, recorded by Message ID, for SOC collection. FLR-01 exit criteria: SOC ownership accepted (09:00†) ✓; authorized containment status recorded ✓; evidence references and timestamps preserved ✓; possible ePHI involvement routed under PRIV-01 (09:26†) ✓.

Escalations and owners: four clean warm-transfer summaries were delivered in the required format, each verified Clean before sending (Component 4).

Receiving function	Transfer / channel	Trigger cited	Sent	Acknowledged / current owner
Contoso Health Security Operations Center (SOC)	WT-00517-SOC†, restricted ServiceNow task	IR-01.B; Check 1 Review	08:55†	09:00† — SOC Tier 2 Triage queue† (incident owner)
Identity & Access Management Operations	WT-00517-IAM†, restricted ServiceNow task	IR-01.B; Check 1 Fail	09:03†	09:07† — Identity Remediation queue†
Information Governance	WT-00517-IG†, restricted ServiceNow task	PRIV-01.B; M365-01; Sharing Fail	09:10†	09:16† — M365 Sharing Review queue†
HIPAA Privacy & Compliance Office	WT-00517-PRIV†, restricted ServiceNow privacy task	IR-01.C; PRIV-01.A; PRIV-01.B; PRIV-02	09:26†	09:31† — Privacy Incident Intake queue†
M365 Purview Audit Administration	Not triggered	A-05: Entra and Purview audit events available	—	—

Open questions and next checkpoint:

- **SOC:** Who controlled the 08:29 ET session and the 08:32 ET file activity? Do 08:29 ET sessions or tokens remain active? What is the actual link target? Did other recipients receive or act on the message?
- **IAM:** Is the CA-TEMP-EXCEPTION membership authorized and current? Was MFA required or satisfied at 08:29 ET? Did any authentication method change after 08:29 ET? What is the containment execution result?
- **Information Governance:** Does the Anyone link conform to policy? Who created it? Was it used anonymously since 08/28/2026? Is the site an approved location with the correct retention?
- **HIPAA Privacy & Compliance Office:** Is there an impermissible use or disclosure, and which PRIV-02 path applies? Which runbook version governs (v1.0 effective 09/04/2026 vs. ticket 09/03/2026)?

- **Timing:** the reporter places the collaboration on 09/02/2026, the scenario intake said “last week,” and the link dates from 08/28/2026. Not reconciled at Tier 1.
- **Next checkpoint:** 09/03/2026 10:00 ET†. Tier 1 will confirm in SIR-00517† that IAM has recorded the containment result and that all four tasks remain owned. Tier 1 takes no further action on the findings; the SOC owns the incident.

Final submission check

- ✓ All six sections are present in this order.
- ✓ Every finding cites a ticket fact or evidence exhibit.
- ✓ Every triggered escalation uses the approved team and channel.
- ✓ No patient or workforce identifier remains in visible or hidden content.
- ✓ No autonomous breach, notification, or actual-access determination appears.
- ✓ The exported PDF was opened and visually checked before submission.

Authoritative sources

- HHS - Summary of the HIPAA Security Rule
- HHS - Summary of the HIPAA Privacy Rule
- HHS - Breach Notification Rule
- HHS - Minimum Necessary Requirement
- HHS - Guidance Regarding Methods for De-identification of PHI
- Microsoft - Compromised identity incident response SOP template
- Microsoft - Phishing investigation playbook
- Microsoft Entra - Investigate identity risk
- Microsoft Entra - Least privileged roles by task
- Microsoft Purview - Search the audit log
- Microsoft Purview - Use sharing auditing in the audit log